

Laporan Audit Keamanan Q3

SecureBank API — 60 Days DevSecOps Mastery Challenge

DevSecOps Engineer

6 Agustus 2026

Laporan Audit Keamanan Q3 — SecureBank API

Objek Audit	SecureBank API (REST API perbankan berbasis Golang)
Lingkup	Secure SDLC, Container, Kubernetes, Cloud (AWS), Red Teaming
Periode Audit	Fase 4 (Hari 46–56) — 22 Juli s.d. 6 Agustus 2026
Standar Acuan	OWASP Top 10, CIS AWS Benchmark v2, MITRE ATT&CK
Status Dokumen	Final (review eksekutif pada Hari 57)

1. Executive Summary

Audit keamanan terhadap aplikasi SecureBank API dilakukan dengan pendekatan **DevSecOps menyeluruh**: analisis kode statis (SAST), analisis dependensi (SCA), pemindaian kontainer, pemindaian infrastruktur-as-code (IaC), pemindaian konfigurasi Kubernetes, pemindaian postur cloud (CSPM), dan simulasi serangan (red teaming).

Sepanjang program 60 hari, seluruh temuan diagregasi dan dipantau melalui **DefectDojo**. Pada re-sync terakhir (6 Agustus 2026), data menunjukkan **6 temuan aktif tersisa** dengan rincian: **0 Critical, 1 High, 2 Medium, 2 Low, 1 Info** — turun signifikan dari kondisi baseline awal (52 temuan agregat, termasuk 1 Critical dan 7 High pada data historis DefectDojo).

Penilaian risiko keseluruhan: MEDIUM, dengan catatan bahwa satu-satunya temuan **High** (kerentanan stdlib pada image kontainer) dapat diselesaikan dengan rebuild image menggunakan versi Go terbaru. Tidak terdapat kerentanan kritis yang terbuka pada state terkini.

Metrik Ringkas

Metrik	Nilai
Total temuan agregat (DefectDojo)	52
Temuan state terkini (re-sync 06-08-2026)	6
Critical / High / Medium / Low / Info	0 / 1 / 2 / 2 / 1
Pipeline keamanan CI/CD (7 scan)	✅ Hijau
Postur cloud (Prowler FAIL)	132 → 106

2. Ruang Lingkup & Metodologi

2.1 Alat & Cakupan

Layer	Alat	Cakupan
Secret Scanning	Gitleaks	Seluruh kode, pipeline CI
SAST	Semgrep (p/golang)	Kode Go: auth, crypto, SQL
SCA	Trivy FS	Dependensi Go (go.mod)
Container	Trivy Image	Base image & binary dependencies
DAST	OWASP ZAP Baseline	Endpoint HTTP localhost:8080
IaC	Trivy config, Checkov	Terraform: S3, SG, VPC, KMS
Kubernetes	Trivy config (KSV), Checkov	Manifest deployment/service
CSPM	Prowler	AWS CIS Benchmark (328 checks)
Admission Control	OPA Gatekeeper	Policy: resource limits, deny-privileged
Runtime Security	Falco (+7 rule)	Syscall detection + alerting ke Slack
Dashboard	DefectDojo	Agregasi & pelaporan temuan

2.2 Pendekatan

1. **Deteksi** — scan otomatis di pipeline CI/CD (gagal-build pada ambang CRITICAL/HIGH).
2. **Verifikasi** — setiap temuan diverifikasi melalui reproduksi dan pemindaian ulang.
3. **Remediasi** — perbaikan diterapkan pada kode, konfigurasi, dan infrastruktur.
4. **Validasi** — pemindaian ulang membuktikan temuan telah teratasi (evidence-based).
5. **Residual** — risiko yang tersisa didokumentasikan dengan status dan rencana tindak.

3. Key Findings (Kondisi Awal / Baseline)

Berikut temuan utama yang teridentifikasi pada kondisi baseline (sebelum remediasi), beserta tingkat keparahan dan sumbernya.

#	Temuan	Severity	Sumber (Hari)
F-01	4 CVE di dependensi Go (termasuk 1 CRITICAL, 3 HIGH)	CRITICAL	SCA Trivy (Day 05)
F-02	Penggunaan MD5 untuk hashing password	HIGH	SAST Semgrep (Day 08)
F-03	SQL Injection via string concatenation	HIGH	SAST Semgrep (Day 08)
F-04	S3 bucket public ACL/policy (Block Public Access off)	HIGH	IaC Trivy/Checkov (Day 20–23)
F-05	Security Group ingress terbuka 0.0.0.0/0 (port 22/80/3389)	HIGH	IaC Trivy/Checkov (Day 20–23)
F-06	16 misconfiguration K8s (privileged, root, tanpa limits)	MEDIUM	Trivy KSV (Day 32)
F-07	Postur cloud: 132 FAIL / 328 checks (4 CRITICAL)	CRITICAL	Prowler (Day 50)
F-08	HTTP tanpa TLS pada endpoint API	MEDIUM	SAST Semgrep (Day 55)
F-09	Kerentanan stdlib Go v1.26.4 pada image	HIGH	Trivy Image (Day 55)
F-10	Gap red teaming: escape K8s, leaked credentials, OPA blind spot	CRITICAL*	Red Team (Day 52–54)

**Temuan F-10 tidak berupa CVE, namun merupakan eksploitasi aktif yang membuktikan gap kontrol — seluruhnya telah dimitigasi.*

4. Mitigation Evidence (Kondisi Setelah Remediasi)

Temuan	Remediasi	Bukti / Validasi
F-01 CVE depen- densi	go get -u patch seluruh dependensi (Day 07)	Scan ulang: 0 CVE CRITICAL/HIGH
F-02 MD5	Ganti ke bcrypt (Day 10)	Semgrep: finding hilang
F-03 SQL Injec- tion	Parameterized query (Day 10)	Semgrep: finding hilang
F-04 S3 public	S3 Block Public Access + encryption (Day 23, 51)	Trivy IaC 14→2 Low; Prowler S3 findings teratasi
F-05 SG terbuka	Perketat SG rules, revoke default SG (Day 23, 51)	Scan ulang: finding hilang
F-06 K8s miscon- fig	readOnlyRootFilesystem, drop capabilities, non- root (Day 33)	Trivy-K8s-post-fix & Checkov: 0
F-07 Postur cloud	Remediasi S3 + SG (Day 51)	Prowler: 132→106 FAIL
F-08 TLS	Belum — rencana termi- nasi TLS	Daftar residual risk
F-09 stdlib image	Belum — perlu rebuild im- age (Go ≥1.26.5)	Daftar residual risk
F-10 Red team gap	OPA deny-privileged, 7 rule Falco, drift-check.sh, CloudTrail aktif (Day 52– 54)	Falco alert → Slack, audit total-violations, drift 0

Perbandingan Sebelum–Sesudah

Layer	Sebelum	Sesudah
Dependensi Go	4 CVE (1 CRITICAL)	0 CRITICAL/HIGH (1 Info)
SAST	2 temuan HIGH	1 Medium (TLS)
IaC (Trivy)	14 temuan	2 Low
IaC (Checkov)	15 failed	0 failed
K8s manifest	16 misconfig	0
Cloud (Prowler)	132 FAIL / 4 CRITICAL	106 FAIL
Runtime red team	blind spots	7 rule + alerting

5. Residual Risk

5.1 Risiko Tersisa

Risiko	Tingkat	Rencana Tindak
CVE-2026-39822 stdlib Go v1.26.4 pada image	HIGH	Rebuild image dengan Go $\geq$ 1.26.5 sebelum rilis production
API tanpa TLS	MEDIUM	Terminasi TLS (sertifikat + ListenAndServeTLS)
CVE-2026-42505 stdlib Go	MEDIUM	Ikut teratasi saat rebuild image
S3 bucket logging nonaktif (AWS-0089)	LOW	Aktifkan bucket logging + integrasi Cloud- Trail
golang.org/x/ crypto openpgp (GO-2026-5932)	INFO	Evaluasi & singkirkan dependency yang menyeretnya

5.2 Risiko yang Diterima

Risiko	Alasan Diterima
Tidak ada WAF	Dijadwalkan implementasi Q4
Agent node k3d NotReady	Keterbatasan lab; cluster non-production
Artefak red team di repo (at- tacker/chaos manifests)	Hanya untuk lab; dilarang deploy ke production

6. Rekomendasi & Roadmap

- Segera (Q3):** Rebuild image securebank:v1 dengan Go $\geq$ 1.26.5 $\rightarrow$ menutup 2 temuan (1 High + 1 Medium).
 - Segera (Q3):** Implementasi TLS pada endpoint API.
 - Jangka pendek:** Aktifkan S3 bucket logging; integrasikan dengan CloudTrail yang sudah aktif.
 - Jangka pendek:** Otomatiskan sinkronisasi DefectDojo (isi variabel DEFECTDOJO_URL di CI) agar data tidak stale.
 - Jangka menengah (Q4):** Implementasi WAF; pemulihan node agent; penjadwalan drift-check sebagai job CI.
-

7. Konklusi

Audit keamanan SecureBank API menunjukkan perbaikan yang terukur dari kondisi baseline: seluruh temuan **Critical** telah teratasi, pipeline keamanan 7-layer berjalan hijau, dan kontrol keamanan berlapis (admission, runtime, audit, alerting) telah terbukti bekerja melalui red teaming. Tersisa **1 temuan High** yang solusinya sederhana (rebuild image). Dengan penyelesaian rekomendasi segera, postur keamanan aplikasi dapat ditingkatkan menjadi **LOW**.

Lampiran

Alat & Versi Utama

Alat	Versi
Trivy	v0.71/v0.72
Semgrep	latest (p/golang)
Checkov	v3.3.2
OWASP ZAP	stable (baseline)
Prowler	latest (AWS)
Falco	helm chart (7 custom rule)
OPA Gatekeeper	helm chart (2 constraint)

Referensi Bukti (Catatan Harian)

Hari	Topik
05–07	SCA Trivy & remediasi dependensi
08–10	SAST Semgrep & remediasi (bcrypt, parameterized)
17–19	Container image scan & signing
20–23	IaC scan & remediasi (S3, SG)
32–33	K8s misconfig scan & hardening
46–47	DefectDojo setup & integrasi
50–51	CSPM Prowler & remediasi
52–54	Red team (escape, leaked creds, chaos)
55	Re-sync data & laporan